

Continuous Control Assessment

Sentinel Nexus — proven control posture (generated from the test run)

Information Security & AI Governance

June 2026

Contents

Assessment Summary	2
Framework Posture	2
Per-Control Proven Status	3
Open Findings (Plan-of-Action seed)	7

Assessment Summary

Unlike the *claims* in the control catalog, every status below is **derived from the pipeline’s JUnit results in this run** — a control is Satisfied only when its bound tests actually executed and passed.

Assessed **36** controls — 30 Satisfied · 0 Failed · 4 Not-Run · 2 Documentation.

Status	Count
Satisfied	30
Failed	0
Not-Run	4
Documentation	2

Framework Posture

Coverage = the share of **applicable** framework items addressed by at least one **Satisfied** control (claimed *and* proven).

Framework	Covered	Applicable	Posture
OWASP Top 10 LLM	9	10	90.0%
MITRE ATLAS	8	8	100.0%
NIST AI 600-1	13	14	92.9%
NIST SP 800-53	28	34	82.4%
NIST CSF 2.0	6	6	100.0%

Per-Control Proven Status

ID	Title	Intent	Assessed	Evidence	Bound tests	Code evidence
AI-GROUNDING	Confabulated-evidence grounding	implemented	Satisfied	complete	TestGroundingEnforcement	controls.py:L58-L74
AI-MEMORY-TTL	Immunity-memory TTL / expiry	implemented	Satisfied	complete	TestMemoryTTL	controls.py:L147-L175
AI-PROVENANCE	AI-origin provenance disclosure	implemented	Satisfied	complete	TestProvenanceDisclosure	controls.py:L178-L192
AI-REVIEW-BOARD	Adversarial review board (per-expert counterparts)	implemented	Satisfied	complete	test_review_board.py, test_review_board_simulation.py	orchestrator.py:L140-L140
IAC-HARDENING	OS / kernel / network hardening baseline	implemented	Not-Run	complete	test_infrastructure.py-not-run	main.yml:L20-L22
ING-DLQ-BREAKER	Durable worker circuit breaker + dead-letter routing	implemented	Satisfied	complete	TestWorkerS3ArchiveDLQ, TestCognitiveFaultDLQ	lib.rs:L44-L60
ING-ZERO-TRUST	Zero-Trust ingestion gateway (HMAC + 3-tier replay defense)	implemented	Satisfied	complete	TestEvidenceIngress	integrity.rs:L211-L213
NC-1-BIAS-AUDIT	Bias/disparity + homogenization scheduled audit	implemented	Satisfied	complete	TestBiasAudit	controls.py:L239-L249
NC-10-VERDICT-LINEAGE	Tamper-evident verdict lineage	implemented	Satisfied	complete	TestVerdictLineage, TestVerdictLedger	response.py:L170-L180
NC-11-ENERGY-ACCOUNTING	Per-run inference energy accounting	implemented	Satisfied	complete	TestInferenceEnergy, TestEnergyAccounting	response.py:L185-L189
NC-2-CALIBRATION	Confidence-calibration ledger	implemented	Satisfied	complete	TestCalibrationLedger	controls.py:L119-L133

ID	Title	Intent	Assessed	Evidence	Bound tests	Code evidence
NC-3-FRONTIER-PIN	Frontier model boot-time version-pin enforcement	implemented	Satisfied	complete	TestFrontierPin Enforcement	controls.py:L195-L201
NC-4-RETENTION	Data retention & decommissioning policy	documented	Documentation	complete	(none)	—
NC-6-ENERGY	Environmental impact estimate	documented	Documentation	complete	(none)	—
NC-7-ENDPOINT-ABUSE	Inference-endpoint abuse / model-extraction monitoring	implemented	Satisfied	complete	TestEndpointQuota, TestVolumeAnomaly, TestMembershipInferenceSignal, TestEndpointAbuseReport, TestEndpointAbuseMonitor	controls.py:L519-L531
NC-8-OVER-RELIANCE	Automation-bias / over-reliance measurement	implemented	Satisfied	complete	TestOverReliance, TestRelianceLedge	controls.py:L351-L365
NC-9-ACTIVE-LEARNING	Active-learning failure capture	implemented	Satisfied	complete	TestActiveLearningFailure, TestActiveLearning	response.py:L196-L201
SEC-BLAST-RADIUS	Blast-radius cap & entity state machine	implemented	Satisfied	complete	test_hunter_contracts.py	state.py:L260-L290
SEC-CANARY	Canary token prompt-leak tripwire	implemented	Satisfied	complete	test_agentic_swarm_contracts.py	orchestrator.py:L233-L233
SEC-DLP-EGRESS	Outbound DLP / sovereign data isolation	implemented	Not-Run	complete	test_cognitive_bypass.py-not-run	sanitizer.py:L59-L73
SEC-DUCKDB-SANDBOX	Read-only data-lake query sandbox	implemented	Satisfied	complete	test_query_cookbook.py	duckdb_query.py:L27-L30
SEC-ENDPOINT-ID	Endpoint identity injection defense	implemented	Satisfied	INCOMPLETE — logic-only (no wired invocation→execution)	TestEndpointIdInjectionDefense	models.rs:L14-L20

ID	Title	Intent	Assessed	Evidence	Bound tests	Code evidence
SEC-FAILOVER	Cascading LLM failover & sovereign degradation	implemented	Satisfied	complete	TestLLMCircuitBreaker	expert_base.py:L25-L25
SEC-IDEMPOTENT-SOAR	Idempotent SOAR execution & deduplication	implemented	Satisfied	complete	test_agentic_swarm_contracts.py	response.py:L374-L377
SEC-MODEL-DOS	Model denial-of-service bounding	implemented	Satisfied	complete	test_agentic_swarm_contracts.py	orchestrator.py:L56-L56
SEC-OUTPUT-SCHEMA	Strict SOAR output-contract enforcement	implemented	Satisfied	complete	test_agentic_swarm_contracts.py	state.py:L139-L174
SEC-REGRESSION-GATE	Deterministic regression / deploy gate	implemented	Satisfied	complete	test_mlops_serving.py	03_eval_model.py:L312-L338
SEC-RLHF-QUARANTINE	Sybil RLHF poisoning quarantine	implemented	Satisfied	complete	TestNATSSubjectAuth	main.rs:L90-L91
SEC-SANITIZER	Cognitive boundary isolation & untrusted-payload wrapping	implemented	Not-Run	complete	test_cognitive_bypass.py-not-run	sanitizer.py:L24-L48
SEC-SUPPLY-CHAIN	Cryptographic model supply-chain integrity (SHA-384)	implemented	Satisfied	complete	test_mlops_serving.py	serve_vllm.sh:L48-L66
SEC-TRAINING-HYGIENE	Training-data hygiene & credential scrubbing	implemented	Satisfied	INCOMPLETE — logic-only (no wired invocation→execution)	test_mlops_serving.py	01_spool_datasets.py:L49-L60
SEC-VECTOR-DIM	Vector dimensionality validation	implemented	Satisfied	complete	test_hunter_contracts.py	qdrant_search.py:L50-L50
SIEM-CONFIG-CONTRACT	SIEM config ↔ fanout index contract	implemented	Satisfied	complete	test_siem_config.py	review_board.py:L139-L140

ID	Title	Intent	Assessed	Evidence	Bound tests	Code evidence
SIEM-COUNTERPART-DISPROOF	Review-board counterpart	implemented	Satisfied	complete	test_siem_review_board.py	review_board.py:L117-L127
SIEM-E2E	SIEM disproof SIEM federation end-to-end conservation	implemented	Not-Run	complete	test_siem_federation_e2e.py-not-run	test_siem_federation_e2e.py:L189-L195
SIEM-TOOL-GUARD	SIEM query tool — read-only / bounded / allowlist	implemented	Satisfied	complete	test_siem_query.py	siem_query.py:L110-L128

Open Findings (Plan-of-Action seed)

Controls claimed **implemented** with a proof gap: bound tests that **failed / did not run**, or an **incomplete evidence chain** (e.g. a lone logic snippet with no wired invocation→execution). A Failed or Incomplete finding turns the build red; a Not-Run finding is a coverage gap (blocking only in `--gate --strict / --full`).

- **IAC-HARDENING — OS / kernel / network hardening baseline** → *Not-Run*. Bound: `infrastructure/tests/test_infrastructu re.py` [not-run]
- **SEC-DLP-EGRESS — Outbound DLP / sovereign data isolation** → *Not-Run*. Bound: `tests/lab_redteam/test_cognitive_bypas s.py` [not-run]
- **SEC-ENDPOINT-ID — Endpoint identity injection defense** → *Satisfied*. Bound: `tests/test_worker_contracts.py::TestEndpoi ntIdInjectionDefense` [resolved=pass] · **evidence:** logic-only (no wired invocation→execution)
- **SEC-SANITIZER — Cognitive boundary isolation & untrusted-payload wrapping** → *Not-Run*. Bound: `tests/lab_redteam/tes t_cognitive_bypass.py` [not-run]
- **SEC-TRAINING-HYGIENE — Training-data hygiene & credential scrubbing** → *Satisfied*. Bound: `tests/lab_mlops_serving/t est_mlops_serving.py` [resolved=pass] · **evidence:** logic-only (no wired invocation→execution)
- **SIEM-E2E — SIEM federation end-to-end conservation** → *Not-Run*. Bound: `tests/lab_siem_federation/test_siem_federatio n_e2e.py` [not-run]